

Incident Response & Digital Forensics - Ramya Sir.

Sarang Sir

8th Jan.

Number System Conversions

1]. Binary to Decimal: 100100111001

$$2048 + 256 + 32 + 16 + 8 + 1 = 2361$$

2]. Hexadecimal to Decimal: A1B8C5

$$10^6 + 11^5 + 12^4 + 8^3 + 16^2 + 5^1 = 10,598,573$$

3]. Octal to decimal: 743924

Not Valid.

TASK

BIOS

Secure Boot

Legacy Boot

UEFI

9th Jan.

→ Controller archi + Chip.

→ Physical layout of hard disk

→ Commands: trim (can be scheduled for memory) Data retrieval is easy on hard drive
Garbage collection not in SSD.
Wear leveling.

HPA: Host Protected Area.

↳ introduced in ATA/ATAPI-4.

↳ reserve portions of the disk for use outside the normal OS.

Types of Booting

→ Cold: Not executing anything. Normal turning on the comp.

→ Warm: Restarting. Finally it's ON.

DCO: Device Config overlay

↳ ability to control disk features & capacity

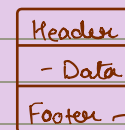
↳ allows multiple manufactures to ship disks while maintaining identical numbers of user-accessible sectors & features across the disk.

↳ Drive replacement.

↳ DCO-1st then HPA.

To retrieve data from HDD we need same cluster of manufacturer. (chip-off tech).

File :- Collection of data or bytes



File headers - metadata.
(can be changed with HxD).

media types file doesn't have footer.

★ Data Carving:

→ Contiguous & non-contiguous allocation.

→ Fragmentation & de fragmentation.

HDD → Main memory → CPU → Cache
(load) ← (process) ↺

★ Data

a. Active • use everyday
• located using wind explorer.

b. Latent → Deleted or partially overwritten
invisible - bit stream carving

c. Archive

↳ Backup
↳ External H.D.

(Recovery)

13th Jan
Ramya Sin

⇒ Data Classification.

- Highly Confidential - Credit card info etc.
- Sensitive - Evaluation, Emp perf., marketing plans, contracts.
- Internal use only - th, hiring.
- Public - nega, no protection.

C - Confidentiality
I - Integrity
A - Availability } Targets data

A - Authentication
A - Authorization
A - Accountability } Targets ppl

⇒ MD5 is not reliable coz of "MD5 collision". Same hash for different files

15th Jan.

Events

↳ Observable occurrence

Incidents

↳ Violation or threat to CSPs, AUPs or std Security practices.

* DOS with multiple PC - NATing.

Class → ← Classless.

i - global ecosystem
I - Internet.

proxy servers → Routers → F/w → Switch (L2/L3) (manageable/non) → IDS/IPS → Internal Subnetting

EDR.

Pharming
Drive by attack.

NOC

SOC

21st Jan.

⇒ Sysinternals utility = Sysmon (Sys monitor).

ipconfig is binary.

⇒ Windows logs

- Application =
- Security =
- System =
- Setup = update logs etc
- Forwarded Events

⇒ Event IDs = 4799, 4625 etc.
(logon)

* Pelican Kit
↳ write blockers
Type R/W S/W

CAINE OS

29th Jan.
Sanam Sir

* Calculation of Data

No of Tracks $\times$ R/w head $\times$ Sector per track $\times$ bytes per sector

* What is Digital Forensics

* Rule 1: Never work on original data.

2: Always use write blocker

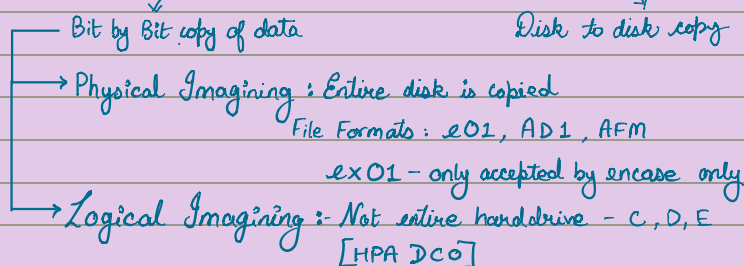
$\Rightarrow$ Imager

$\Rightarrow$ Forensic Image: Bit by bit copy

$\rightarrow$ It also has meta data

RAW file .mem - don't have metadata

Q. Diff. b/w Forensic Imaging & Cloning



Write blocker is a specialized device which allows you to connect hard drive or pendrive in read-only mode to prevent any overwriting.

* On board SSDs can't be removed.

+ why it is imp + some examples.

Define :- Imaging, Imager, Cloner

write blocker, DF, Faraday Bag, anti-static Bags

Types of Imager :-

$\rightarrow$ Software :- FTK, Autopsy

$\rightarrow$ Hardware :- TX1, TD2U, TX2, FALCON2, FALCON Neo 2

Journal Book :- Assignment (Cyber Crime Inv. Manual - JH Police)

• drives, connectors

Why write blockers aren't used for mobile.

$\rightarrow$ Running OS

$\rightarrow$ Pushing is diff.

11th Feb.
Lab - RS

Three Challenges of Logs :-

OEM = ?

1. Volume :- Large amt of data, diff data sources produce huge amt of data.
2. Velocity :- Increases with high speed, storage & analysis becomes difficult
3. Veracity :- Diff OEMs or devices have diff log formats, normalizing it is a challenge

Parsers :-

Log analysers :-

SAWILL :- Log analyser tool $\rightarrow$ Password Checking/Changing
 $\rightarrow$ Email Setup - for getting reports in mail.
 $\hookrightarrow$ Bounces & Bouncers $\rightarrow$ Hop counts similar to traceroute.
 $\hookrightarrow$ macros.
 $\hookrightarrow$ Filter creation

12th Feb.
Sarang Sin

Downloading FTK imager.

1. Add Evidence :- Physical - Entire drive
Logical - Partitions (C,D,E)
Image file
Contents of folder
2. Physical → Source Path → 0 - operating sys drive, Others would be external drives
3. Basic Data is actual partition where data is stored. [55 AA - means GPT partition - Every thing else is empty or 0]
- MBR Record - online
4. Image Mounting
5. Create disk image :- Physical, Logical, Image, Contents, pos, Ferrico Device (CD/DVD)

★ Options :- Verify image, pre-calculated statistic.
Create directory listing of all files - scans entire system & creates index.

★ Add :- Raw (dd), SMART, EO1 - (majority accepted), AFF

Saving point should be of more storage while creating image. Same place pe don't save the file

★ Details like : Case No, Evidence No, Unique Description, Examiner detail, Notes

★ Image Destination

↳ Fragment Size - No of files you want to make (ideal 4300 MB).

↳ Compression → 0 (none), 9 (best) - ✓

↳ AD Encryption - Access Data - Generally not used coz of tool dependency [encrypted format: Encase - ex01].

★ Capture Memory → Path → filename.mem → This file can be used in autopsy or volatility for more.

★ Obtain Protected Files :- SAM, Software, Security, System + antiser.dat, userclass.dat

↳ These are the 4 files imp for obtaining info. from registry of windows

↳ Password recovery & all registry files.

⇒ After getting these files we can use tool F-RAT 2.0 to analyse these files. reg analysis tool

Questions

1. Diff b/w MBR & GPT Partition

2. VBR (Volume)

3. Diff b/w volume & partition
(contains Filesystem) (not contains Filesystem) logical Section

4. Check FS of your system

Check disk from disk management

5. Offset or starting point

13th Feb.
Sarang
Sir

#

FILE SYSTEM!!

- Hardware Independent
- Software Independent

HFS+, APFS,
EXT(2,3,4), UFS, CDFS
NTFS, FAT

- File System stores data on device so data can be retrieved by the system or user.
- Logical Block address - Location of file's data
- Metadata includes file's location & size of data so system can retrieve it from hardware.
- Multiple blocks of data may be necessary for files that are too large to be stored in a single block & can't be stored in consecutive blocks on device.

★ Information available in File system.

1. General FS info
2. Contents of File
3. Meta data
4. File name
5. User quota statistics
6. File system journals

★ Essential File system data

1. File name
2. Address / Location
3. Pointer

★ Non-Essential File system data

↳ For convenience, NOT for basic functionality

1. Creation, modification, access date
2. Author name
3. File size

FAT: File Allocation Table

- ↳ memory card, pendrive, USB 'thumb drives'.
- ↳ Each file & directory is allocated a data structure, called data entry.
- ↳ Used in both content & metadata storage.
- ↳ FAT 12, 16, 32 → Diff in storage or no. of entries it can store.
- ↳ Boot Sector - FS category of data is found here
 - ↳ Contains additional data, including sector address of backup copy of boot system.

↳ Has FSINFO - DS - contains info about location of next available cluster & total amt of free cluster.

★ Majorly 3 Types of area

- a. Reserved area: Basic FS info
- b. FAT area: 1st & backup FAT structure - directory no, clusters, Location etc.
- c. Data area: Cluster - actual files are stored here

★ Check in FTK

- ↳ 1st Sector tells us if the partition is ^(55 AA) MBR or GPT (Protected MBR).
- ↳ FAT data would be in volume - Partition - Boot Sector, Jump instruction

Questions

1. Diff b/w cluster & sector ★ Check cluster size of ur Comp.
(available inside vol - logical) (HDD) [One cluster can have multiple sectors]
2. How to change cluster size.
3. Slack Space: diff b/w allocated space & occupied space [used for over-written files]

Steps to Handle an Incident ~ SANS

① Preparation : Preventing Incidents

- Risk Assessments
- Host Security - Servers or devices.
- Network Security - NOC
- Malware Prevention
- Awareness & Training.

② Identification : Attack Surface & Attack Vectors & Attack Carriers

- Web
- Email Totological based SQL.
- Impersonation
- External / Remoral media
- Improper usage
- Loss or Theft of equipments

* Insecure Bank.

⇒ Sources of Precursors & Indicators

* Alerts

- IDS/IPS

- SIEM

- AV

- FIM

* Logs

- OS

- Service

- App (internal)

- Network

* Publicly available Info (TI)

* People

③ Incident Handling : First Hand / Initial Analysis

⑥

(Interaction - Getting knowledge of system, backup, workflow)

- Profile network & systems - Understand the spread & no of devices connected.
- Understand normal behaviours - normal files etc.
- Create a log retention policy
- Perform event correlation. (Eg; Time stamp issue, diff timestamps).
- Clock Synchronized

* Timeline Analysis.
UTC: 00:?? ✓
NLP: 30.

④ Recommendations for performing initial analysis

- Knowledge base of info
- Get info from internet

⑤ Incident Documentation

Should Contain

- Immediately start recording
- Logbook, audio or video recordings
- Signed by incident Handler.

a. Current Status

b. Summary

c. Indicators

d. Actions taken

e. CoC.

f. Impact Assessment

g. Contact Info

h. List of evidences

i. Comments during the process.

24th Feb.

Incident Prioritization

Scenario A:

PII is leaked

Scenario B:

DOS attack happening.

Priority can be based on

- a. recoverability impact: Regular, Supplemented, Extended, Not Recoverable
(no impact) (minimal effect) (lost ability to provide service) (no longer able to provide critical services to any users).
- b. Fun impact: None, Low, Medium, High
- c. Information impact: CIA: None, Privacy Breach, Proprietary Breach, Integrity Loss
(No info. withheld, changed, accessed or deleted) (PII Unlaw. accessed or exploited) (Unclassified PS with Acc. or Exp.) (Sensitive or Confidential data accessed or exploited)

Containment:

Criteria

1. Potential damage to & theft of resources.
2. Need for evidence preservation
3. Service Availability
4. Time & resources needed to implement the strategy.
5. Effectiveness of strategy
6. Duration of solution.

SIEM
EDR/XDR
CTI

cello2
roadmap.sh

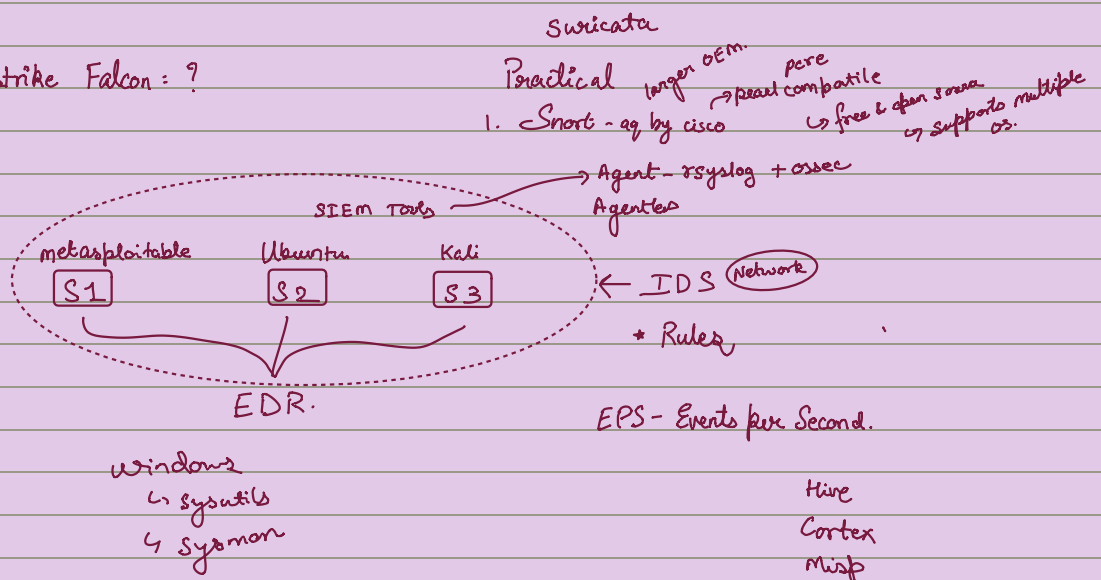
* Identifying attacking hosts.

1. Validating attacking host's IP add.
2. Researching attacking host through search engines.
3. Using Incident Databases
4. Monitoring possible attacker comm. channels.

* Eradication

* Recovery.

Crowdstrike Falcon: ?



requirements

- pcap
 - PCRE
 - Libdnet
 - DAQ
- Sudo apt install -y build-essential

19th Feb.
Sarang Sir.

Learn little & Big endian conversion.

Q. Find Cluster Size (in KB).

* Find reserved area size

FO OA

Interchange it : OA FO

00:10 15:0 - Decimal
0000:1010 1111:0000 - Binary
= 101011110000 = 2800 bytes
Ans in Binary Decimal

Convert into KB.

$\frac{2800 \times 512}{1024} = 1400 \text{ KB}$
??

Q. FF FF
15 15 15 15
1111 1111 1111 1111
65535.

* MBZ

Q. How many sectors are there in 16 GB & How are they stored?

16 GB in Bytes will become

$16 \times 1024 \times 1024 \times 1024 \text{ bytes} = 2$

1024 has 2 sectors (1 sector = 512 bytes)

2 has ? sectors

$\frac{2 \times 2}{1024} = \frac{16 \times 2 \times 1024 \times 1024 \times 1024}{1024} = 33554432$

Now convert this ans into HexaDec.

Ans = 02:00:00:00
upper lower

Now interchange the upper & lower bytes. so it will become

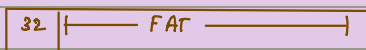
0002:0000
upper lower

20th Feb.



↓
has info about partition.

FAT = 32



Now divided into clusters * → Find clusters

Repackaging
converting - add own
custom header for
recovery.

* Converting = ? happens based on file struct.



2800
2832 -
Physical
address

29968 - Logical
29968 + 2832 - Physical
(117744 * 2 = 29968)
cos there are
2 FATs

Q Size of data area

Total size - FAT - Reser - 32
area
31720000

2 FATs.

FSINFO = ?

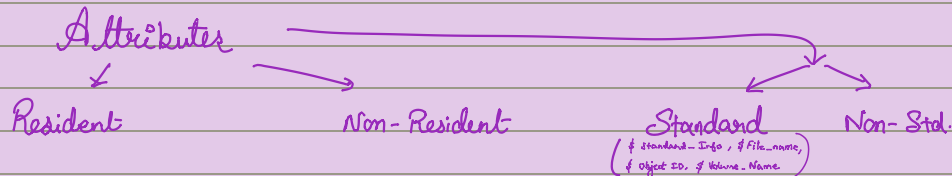
3rd Mar

NTFS : New Technology File System.

1. Indexing is better
2. Corruption is less
3. Security is better
4. Journaling Support
- 5.

→ Has MFT (Master File Table)

MFT Records



Each MFT record has unique FRN (File Reference No).

- \$ First letter is capital.
- First 16 bits reserved for file metadata by microsoft.

FTK
Scanning MFT
Table by NTFS.

1. \$MFT
2. \$MFT mirror (for recovery) - replica of \$MFT
3. \$Log File *
4. \$Volume
5. \$Bitmap

16 Std entries

↳ understand the purpose.

ISO

\$ Badcluster

\$ Extend

\$ Boot

\$ Secure
\$ Upcase

\$ USNJournal *

12th March

⇒ Who on which org lists zero day vulnerabilities?

CSIRT? CERT?

⇒ SOC Roles (Analyst, Engineer, CISO etc)

⇒ Need of SOC

⌘ What are PLM files??

⌘ Callos fields?

⇒ Tool: Recorded future ^{APT for TI} (6Cr) fields

⇒ OTX - Threat Intel - Older part

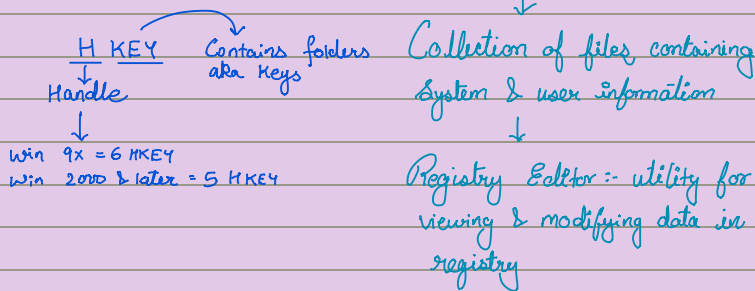
or version of 'alien vault'

⇒ Tellos ??

27th March
Sarang Sir

Windows Registry

(Central Hierarchical Database)
(Records info specific to users for tracking)



Subkey :- Subfolder
Branch :- Key & its contents [including Subkey]
Value :- file & data content [name & value]
Default value (each user has Ntuser.dat)
Hives :- specific branches in HKEY-USER
 ↳ HKEY_LOCAL_MACHINE
 ↓
 /Software has SAM, Security, System & Components

Extract reg file from FTK using 'obtain protected file'

F-RAT
 ↳ Tool
 ↳ To read 'protected file'

→ Win Reg. replaced the configuration & initialization (.ini) files used in Windows versions prior to Win NT.

⇒ Each registry file begins with the header 'regf' & each entry starts with header 'hbin' → can be recovered using carving.

⇒ Registry & info about system & apps are located in Windows\System32\Config directory
⇒ User specific info stored in user profile directories (NTUSER.DAT & USRCLASS.DAT)

SOFTWARE	SYSTEM	SAM
%Systemroot%\Windows\System32\Config	%Systemroot%\Windows\System32\Config	%Systemroot%\Windows\System32\Config
⇒ Contains info on installed sw, including win OS & Microsoft app.	⇒ The key itself contains 2 or more control sets → last known good & current control sets → of the last time the system was booted.	⇒ Security Accounts Manager ⇒ Info about local system like local users, encrypted password, loc of user's registry hive ⇒ Domain acc. will be stored in AC, may not be stored locally in SAM
⇒ Separate entries exist in sw key under HKEY\LocalMachine\Software\Wow6432 Node		

SECURITY	NTUSER.DAT	USERCLASS.DAT
⇒ HKLM\SECURITY	⇒ Contains info specific to a user, including settings, MRU, start-up scripts or apps, preferences & more.	⇒ Added in win 7. ⇒ Contains info previously stored in NTUSER.DAT. Specifically the Shell-Bag info
⇒ Security DB of domain info into which current user is logged in		⇒ Shell bags are registry artifacts that store user preferences for directories such as window size, Sorting order, & placement on screen.
⇒ Linked to local machine & Kernel reads it to enforce security policy		

10th Apr.

⇒ Seizure Details

* Digital Evidence Collection form → (seizing power lies with high/above ranking officers (PI))
* Seizure memo (Panchnama).

Only police inspector can remove the evidence from evi room. It should have the same seal like at the time of seizure.

jit police cyber crime investigation manual

Only DSP or DCP can sign the Certificate of authority aka forwarding authority Eg: given to NFSU or someone to check.

Why hashing is difficult at crime scene?

1. Time Taking.
2. Tool Dependency
3. Active OS like mobile, difficult to get hash

At the time of submission multiple certificates has to be signed.

* parcel opening form is also there.

